TLP:CLEAR

ОТЧЁТ ОБ ИНЦИДЕНТЕ

Перехват аккаунта WhatsApp через фишинговый кит «Defisher»

WhatsApp Device Linking • Phishing Kit • PhaaS • Bulletproof Hosting • Aeza Group

Параметр	Значение
Дата инцидента	**4 марта 2026**
Дата анализа	**5–6 марта 2026**
Классификация	**Account Takeover / WhatsApp Device Linking**
Уровень угрозы	**ВЫСОКИЙ**
Вектор атаки	**Фишинговая ссылка через Signal**
Инструмент	**Фишинговый кит «Defisher» (PhaaS-платформа, Next.js)**
Хостинг	**AEZA GROUP (AS210644)** — bulletproof hosting, санкции США (OFAC)
Статус	**Активен на момент анализа (06.03.2026)**

1. Краткое заключение

Пострадавший получил ссылку через мессенджер Signal, ведущую на фишинговый сайт trust-authorization[.]tech. Сайт имитировал интерфейс WhatsApp Web и запрашивал ввод номера телефона. После ввода номера жертве был показан 8-значный код привязки устройства с инструкцией ввести его в настройках WhatsApp.

В результате устройство атакующего было привязано к аккаунту WhatsApp пострадавшего. Помимо доступа к сообщениям в реальном времени, при привязке WhatsApp автоматически синхронизирует недавнюю историю переписки (включая фото, видео и документы) на новое устройство. Это означает, что атакующий получил доступ как к новым сообщениям, так и к архиву переписки.

Фишинговый кит идентифицирован как «Defisher» — коммерческая Phishing-as-a-Service (PhaaS) платформа на базе Next.js с многопользовательской панелью управления, управлением доменами/прокси и выгрузкой перехваченных сессий. Инфраструктура размещена на сервере AEZA Group (AS210644) — российского bulletproof-хостинга, находящегося под санкциями США (OFAC) с июля 2025 года.

Активное тестирование (6 марта 2026) подтвердило, что сервер по-прежнему функционален. Встроенная в кит фильтрация номеров СНГ не активирована оператором — номера из России, Украины, Казахстана и Беларуси принимаются наравне с иностранными.

2. Механизм атаки

2.1. Цепочка атаки

Атака использует легитимную функцию WhatsApp «Связанные устройства» (Linked Devices), позволяющую привязать дополнительное устройство к аккаунту по 8-значному коду. Фишинговый кит автоматизирует получение этого кода через серверное взаимодействие с WhatsApp API.

- Жертва получает ссылку через Signal (или другой мессенджер)
- При переходе загружается Next.js приложение, имитирующее WhatsApp Web
- Страница автоматически определяет страну жертвы через ipapi.co
- Жертва вводит номер телефона
- Через WebSocket (Socket.IO) номер передаётся на управляющий сервер panel-my-test[.]online
- Сервер инициирует процедуру привязки устройства и получает 8-значный код
- Код отображается жертве с инструкцией: «Откройте WhatsApp → Связанные устройства → Привязать устройство → Привязать по номеру телефона → Введите этот код»
- Жертва вводит код — устройство атакующего привязано к аккаунту
- WhatsApp автоматически синхронизирует недавнюю историю переписки на устройство атакующего

2.2. Социальная инженерия

Фишинговая страница оформлена как канал «Report channel» (16 подписчиков) с аватаром — стоковым изображением человека, пишущего на бумаге. Пользователь Signal, получивший ссылку, мог воспринять её как запрос на верификацию или подключение к каналу обратной связи.

Страница в точности воспроизводит интерфейс WhatsApp Web: логотип, цветовая схема (#008069), типографика. Заголовок HTML-страницы — «WhatsApp».

2.3. Фильтрация СНГ: код есть, фильтр выключен

В клиентском коде кита обнаружен обработчик для блокировки номеров из стран СНГ:

socket.on("sng", () => { error = "Извините, ваш номер в зоне СНГ, ошибка." })

Однако активное тестирование (6 марта 2026) через WebSocket API показало, что фильтр не активен в данной кампании. Номера из России (+7), Украины (+380), Казахстана (+7) и Беларуси (+375) были приняты сервером, и для каждого сгенерирован реальный 8-значный код привязки WhatsApp. Событие "sng" ни разу не было получено.

Геофильтрация СНГ — встроенная опция кита Defisher, реализованная на стороне сервера. Оператор данной кампании её не активировал. Вероятно, это настройка в панели управления.

Русскоязычные строки в коде ("Извините, ваш номер в зоне СНГ", "Ошибка определения страны", 404-страница панели) указывают на русскоязычного разработчика кита, но не обязательно на русскоязычного оператора конкретной кампании.

3. Фишинговый кит «Defisher»

3.1. Технический стек

Компонент	Технология
Фронтенд	Next.js (React), Tailwind CSS, Radix UI
Бэкенд	Node.js, Socket.IO (WebSocket)
Панель управления	Next.js (отдельный build, /auth)
Прокси	Nginx Proxy Manager v2.14.0 + OpenResty
GeoIP	ipapi.co
Авторизация	JWT в cookie

3.2. Режимы работы

Кит поддерживает два режима перехвата аккаунта:

- QR-код — генерация QR-кода WhatsApp Web для сканирования жертвой
- Телефонный номер — получение 8-значного кода привязки устройства (использован в данном инциденте)

3.3. Возможности

- Конфигурируемый претекст: заголовок, фото, количество подписчиков
- Геофильтрация: опциональная блокировка номеров СНГ (не активна в данной кампании)
- Опциональное подтверждение (confirmation) с кастомным текстом и изображением
- Управление ошибками: параметр showerror — при ошибке показать «Verification completed!» вместо ошибки
- Статистика: количество просмотров, вводов номера, успешных привязок
- Опциональный редирект после успешной привязки
- Управление доменами и прокси через API
- Выгрузка перехваченных сессий (архивы аккаунтов)

3.4. PhaaS-платформа

Реверс-инжиниринг JS-кода панели управления выявил полнофункциональную Phishing-as-a-Service платформу с многопользовательской архитектурой:

Категория	Функциональность
Управление пользователями	Создание/удаление/бан пользователей, смена паролей (admin)
Кампании	Создание/удаление шаблонов (кампаний), генерация API-ключей
Домены и прокси	Привязка доменов и прокси к пользователю, создание через API
Сессии	Просмотр/скачивание/удаление перехваченных аккаунтов (архивы)
Настройки	URL редиректа, тип ошибки — настраиваются per-user
Авторизация	JWT, ролевая модель (admin/user), русскоязычные сообщения об ошибках

Defisher — это не инструмент одного оператора, а сервис, предоставляемый множеству пользователей. Каждый пользователь управляет своими кампаниями, доменами и перехваченными сессиями.

3.5. Языковые маркеры

Код содержит русскоязычные строки, указывающие на русскоязычного разработчика:

- "Извините, ваш номер в зоне СНГ, ошибка." — фильтрация СНГ
- "JWT токен не найден в куки", "Неверные логин или пароль", "Заполните все поля" — авторизация
- "Ошибка определения страны" — геолокация
- "404 - Страница не найдена", "На главную" — панель управления
- "Полученные домены:", "Ошибка при создании доменов через API:" — отладка

3.6. API и статистика кампании

Открытый API-эндпоинт /api/content/get раскрывает конфигурацию и статистику фишинговой страницы:

Параметр	Значение	Описание
id	8	Порядковый номер кампании на сервере
type	wame	WhatsApp ME — тип атаки
auth	phone	Режим: привязка по номеру телефона
viewCount	210	Количество просмотров страницы
numberInputCount	73	Количество вводов номера телефона
validCount	0	Количество успешных привязок (метрика кита)
wameTitle	Report channel	Название канала-приманки
wameSubscribers	16	Фейковое количество подписчиков
showerror	off	Не показывать ошибки жертве
timestamp	2026-03-04T06:58:41Z	Дата создания кампании

Идентификатор id=8 означает, что на данном сервере было создано как минимум 8 фишинговых кампаний. Конверсия просмотр→ввод номера составила 34.8% (73 из 210) — высокий показатель, характерный для целевой рассылки через мессенджер.

4. Инфраструктура

4.1. Сервер

Параметр	Значение
IP-адрес	147.45.43[.]133
ASN	AS210644 (AEZA-AS)
Провайдер	Aeza International LTD
RIPE Handle	ORG-AGL38-RIPE
Юрлицо (UK)	311 Shoreham Street, Sheffield, S2 4FA, United Kingdom
Юрлицо (RU)	AEZA GROUP LLC, Room 1N, Office 603, Hse 15, Bldg 1, Zolnaya St., SPb 193318, RU
Abuse	support@my-aeza[.]net
Подсеть	147.45.43.0/24 (Aeza-Network), создана 2024-01-09
Локация сервера	Frankfurt, DE
ОС	Ubuntu (OpenSSH 9.6p1-3ubuntu13.5)
Web-стек	OpenResty + Nginx Proxy Manager v2.14.0
Метки Censys	BULLETPROOF

AEZA Group — два юридических лица: Aeza International LTD (UK, Sheffield) и AEZA GROUP LLC (RU, Санкт-Петербург). Квалифицирован как bulletproof hosting. В апреле 2025 года офисы AEZA обысканы ФСБ. В июле 2025 года AEZA включена в санкционный список OFAC (США) за предоставление инфраструктуры для кибератак.

4.2. Таймлайн инфраструктуры

Дата/время (UTC)	Событие
2026-02-17 05:32	Установка Nginx Proxy Manager на VPS (Last-Modified порта 80)
2026-02-17 05:33	Настройка NPM admin panel (Last-Modified порта 81)
	↓ 13 дней — подготовка Defisher, настройка бэкенда
2026-03-02 06:30:09	Регистрация trust-authorization[.]tech (PDR Ltd.)
2026-03-02 06:30:17	Регистрация panel-my-test[.]online (PDR Ltd.) [+8 сек]
2026-03-02 06:49	Выпуск TLS-сертификатов (CT log entry_timestamp)
	↓ 2 дня — настройка кампаний #1–7
2026-03-04 06:58	Создание кампании #8 (текущий инцидент)
2026-03-04	Рассылка фишинговых ссылок через Signal
2026-03-05	Обнаружение инцидента, начало анализа
2026-03-06 06:11	Активное тестирование: сервер по-прежнему активен

Оператор установил VPS за 13 дней до регистрации доменов. Это указывает на подготовительный этап: установка Defisher, настройка бэкенда, тестирование. Домены были зарегистрированы пакетно и подключены к готовому серверу за минуты.

4.3. Домены

Домен	Назначение	Регистрация
trust-authorization[.]tech	Фишинговая страница	2026-03-02T06:30:09Z
panel-my-test[.]online	Панель управления + WebSocket API	2026-03-02T06:30:17Z

Оба домена зарегистрированы с разницей в 8 секунд (пакетная регистрация) через регистратор PDR Ltd. (PublicDomainRegistry.com). DNS-серверы: ns1-4.timeweb.ru/org (Timeweb — российский хостинг-провайдер). WHOIS скрыт за IDCPrivacy Service. Сертификаты Let's Encrypt появились в логах Certificate Transparency через 19 минут после регистрации доменов.

4.4. Порты и сервисы

Порт	Сервис	Назначение	Last-Modified
22/tcp	OpenSSH 9.6p1	Администрирование	—
80/tcp	Nginx Proxy Manager + OpenResty	Default page / редирект	2026-02-17 05:32
81/tcp	Nginx Proxy Manager v2.14.0	Панель NPM (открыта извне)	2026-02-17 05:33
443/tcp	OpenResty (TLS)	Фишинговые страницы + API	—

Порт 81 — панель Nginx Proxy Manager, доступная извне без авторизации по HTTP. API возвращает версию (2.14.0) и статус. Дефолтные учётные данные сменены.

4.5. DNS-записи trust-authorization[.]tech

Тип	Значение
A	147.45.43[.]133
MX	10 mx1.timeweb.ru, 20 mx2.timeweb.ru
TXT	v=spf1 include:_spf.timeweb.ru ~all
NS	ns1-4.timeweb.ru/org

5. Активное тестирование (6 марта 2026)

Для верификации функциональности кита и проверки фильтрации СНГ проведено активное тестирование через WebSocket API (Socket.IO подключение к panel-my-test[.]online/api/socket). Использованы заведомо невалидные номера телефонов.

5.1. Результаты тестирования

Номер	Страна	СНГ?	Результат
+48512000000	Польша	Нет	Код привязки получен
+79510000000	Россия	Да	Код привязки получен
+380501000000	Украина	Да	Код привязки получен
+77010000000	Казахстан	Да	Код привязки получен
+375291000000	Беларусь	Да	Код привязки получен
+48999000111	(невалидный)	—	phone-number-error
+11234567890	США (невалидный)	—	phone-number-error

5.2. Выводы тестирования

- Фильтр СНГ не активен — все номера из стран СНГ (RU, UA, KZ, BY) приняты сервером, для каждого сгенерирован реальный код привязки WhatsApp
- Валидация номера выполняется на стороне WhatsApp API — невалидные номера отклоняются с ошибкой phone-number-error
- Коды привязки — реальные: сервер обращается к WhatsApp API и получает настоящие linking codes, что подтверждает полную функциональность кита
- Геофильтрация СНГ — опциональная серверная настройка кита Defisher, не активированная оператором данной кампании

6. Индикаторы компрометации (IOC)

6.1. Сетевые индикаторы

Тип	Значение	Описание
Domain	trust-authorization[.]tech	Фишинговая страница
Domain	panel-my-test[.]online	C2 панель / WebSocket API
IP	147.45.43[.]133	Сервер (Aeza, AS210644, Frankfurt)
ASN	AS210644	AEZA-AS, bulletproof hosting
Netblock	147.45.43[.]0/24	Aeza-Network
URL	hxxps://trust-authorization[.]tech/pUsl9nuZo649dKua0HL7uG5npbYAq1bn	Фишинговая ссылка
URL	hxxps://panel-my-test[.]online/api/socket	WebSocket endpoint
URL	hxxps://panel-my-test[.]online/auth	Панель управления Defisher

6.2. TLS-сертификаты

Домен	Issuer	Serial	CT log timestamp
trust-authorization[.]tech	Let's Encrypt E7	0571f6a08d8bad...012108	2026-03-02 ~06:49 UTC
panel-my-test[.]online	Let's Encrypt E8	06390e30192e87...4a46	2026-03-02 ~06:49 UTC

6.3. SSH fingerprints

Тип	Значение
HASSH	e42184b06d45385a906f0803d04c83da
Host Key SHA256	67e1fe70de94c56a515ae423ac6eded53e98a20cc7732114f661b372de82f934

6.4. Build ID (Next.js)

Компонент	Build ID
Фишинговая страница	U2cF4qdrSAKoVe_6ATRWM
Панель управления	wNL_QTpqVok6FnMxIeW9R

7. MITRE ATT&CK

ID	Техника	Применение в инциденте
T1566.002	Spearphishing Link	Ссылка отправлена через Signal
T1078	Valid Accounts	Перехват сессии WhatsApp через device linking
T1583.001	Acquire Infrastructure: Domains	Регистрация trust-authorization[.]tech + panel-my-test[.]online
T1583.003	Acquire Infrastructure: VPS	Bulletproof hosting на AEZA (AS210644)
T1588.002	Obtain Capabilities: Tool	PhaaS-платформа «Defisher»
T1036.005	Match Legitimate Name	Имитация интерфейса WhatsApp Web
T1071.001	Application Layer Protocol: Web	WebSocket (Socket.IO) для C2-коммуникации
T1530	Data from Cloud Storage	Доступ к переписке через linked device

8. Рекомендации

8.1. Немедленные действия

- Отключить неизвестное устройство: WhatsApp → Настройки → Связанные устройства → удалить подозрительное устройство
- Проверить все связанные устройства и удалить неизвестные
- Включить двухэтапную проверку: Настройки → Аккаунт → Двухэтапная проверка
- Уведомить контакты о возможной компрометации переписки

8.2. Оценка ущерба

С момента привязки устройства до его отключения атакующий имел доступ ко всем входящим и исходящим сообщениям в реальном времени. WhatsApp linked device получает сообщения синхронно с основным устройством.

Помимо доступа к новым сообщениям, при привязке устройства WhatsApp автоматически синхронизирует недавнюю историю переписки (включая фото, видео и документы). Основной телефон передаёт зашифрованный пакет сообщений на новое устройство, где они расшифровываются и сохраняются локально. Объём синхронизированной истории зависит от типа устройства.

Таким образом, атакующий мог получить доступ не только к сообщениям, поступившим после компрометации, но и к архиву более ранней переписки.

8.3. Превентивные меры

- Не переходить по ссылкам из непроверенных источников, даже если они пришли через защищённые мессенджеры
- Никогда не вводить коды привязки устройств на сторонних сайтах
- Регулярно проверять список связанных устройств в WhatsApp
- Включить двухэтапную проверку WhatsApp (6-значный PIN)

8.4. Для SOC/ИБ

- Блокировать домены trust-authorization[.]tech и panel-my-test[.]online
- Мониторить подсеть 147.45.43[.]0/24 (Aeza) — вероятны аналогичные инстансы
- Искать в URLScan/CT logs другие домены с паттерном: Timeweb NS + PDR registrar + Aeza hosting
- Next.js Build ID U2cF4qdrSAKoVe_6ATRWM может встречаться на других фишинговых доменах того же оператора

TLP:CLEAR — Этот документ может распространяться без ограничений.